

Információrendszerek minőiségbiztosítása és auditja

Alapfogalmak

Adatbiztonsági alapfogalmak

Mit védünk? Mitől? Mi történik, ha nem sikerül?

Adatbiztonsági alapfogalmak

Mi történne, ha holnap eltűnne minden adatunk?

Reggel bekapcsoljuk a számítógépet...

- nincs levelezés
- nincs ügyféladatbázis
- nincs könyvelés
- nincs dokumentumtár
- nincs rendelési rendszer
- nincs mentés

KÉRDÉS: Mi lenne az első dolog, ami miatt pánikba esne egy vállalat?

Adatbiztonsági alapfogalmak

Az adatbiztonság nem egyenlő a vírusirtóval

ADATBIZTONSÁG ≠ VÍRUSIRTÓ

Az adatokat fenyegetheti:

- illetéktelen hozzáférés
- jogosulatlan módosítás
- törlés vagy elvesztés
- rendszerleállás
- technikai hiba
- emberi hiba
- szándékos támadás

Adatbiztonsági alapfogalmak

Adat és információ

ADAT

Rögzített, feldolgozható tény, jel, érték vagy karakter.

INFORMÁCIÓ

Az adat értelmezett formában információt hordoz.

Példa:

38 „A szerver hőmérséklete 38 °C.”

KÉRDÉS: A „105 000” önmagában adat vagy információ?

Adatbiztonsági alapfogalmak

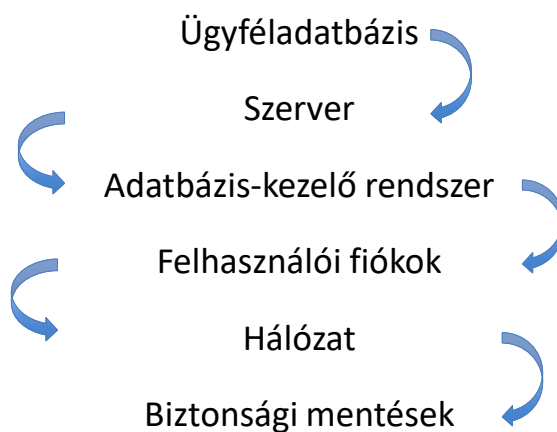
Mi az információs vagyon?

- adatbázis
- dokumentum
- szerver
- alkalmazás
- konfiguráció
- biztonsági mentés
- felhasználói fiók
- üzleti titok
- informatikai infrastruktúra

NEM MINDIG AZ ESZKÖZ A LEGFONTOSABB.

Adatbiztonsági alapfogalmak

Mit kell megvédenünk?



Melyik ezek közül az adatbiztonság tárgya?

Adatbiztonsági alapfogalmak

A három alapkérdés – CIA

MIT AKARUNK BIZTOSÍTANI?



BIZALMASSÁG – Ki láthatja?

✓ SÉRTETLENSÉG – Ki változtathatja meg?



RENDELKEZÉSRE ÁLLÁS – Mikor használható?

Confidentiality – Integrity – Availability

Adatbiztonsági alapfogalmak

Bizalmasság

Az információhoz csak az arra jogosultak férhetnek hozzá.

Példák:

- ügyféladat
- fizetési adatok
- jelszó
- munkaszerződés
- üzleti terv

Egy munkatárs megnyitja más fizetését tartalmazó fájlt. Mi sérül?

Adatbiztonsági alapfogalmak

Sértetlenség

Az adat:

- pontos
- teljes
- hiteles
- jogosulatlanul nem módosított

Példa:

Eredeti: Ügyfél tartozása: 100 000 Ft

Módosított: Ügyfél tartozása: 10 000 Ft

Az adat továbbra is elérhető. Akkor mi a probléma?

Adatbiztonsági alapfogalmak

Rendelkezésre állás

Az információ és az informatikai rendszer akkor és úgy legyen elérhető, amikor az arra jogosultnak szüksége van rá.

Példák:

- szerverhiba
- áramszünet
- zsarolóvírus
- hálózati kiesés
- túlterhelés
- hibás frissítés

Adatbiztonsági alapfogalmak

Egy incidens, három következmény

Támadó	esemény	sérülés
1. megszerzi az adatbázist	Adatlopás	BIZALMASSÁG
2. módosítja az adatokat	Adatmódosítás	SÉRTETLENSÉG
3. titkosítja az adatbázist	Hozzáférés megtagadása	RENDELKEZÉSRE ÁLLÁS

Adatbiztonsági alapfogalmak

Gyors CIA-kvíz

MELYIK SÉRÜL ELSŐSORBAN?

- A) Ügyféllista rossz címzetthez kerül.
- B) Könyvelési adatokat átírnak.
- C) A szerver három napig nem működik.
- D) Ellopják a titkosítatlan laptopot.

A – bizalmasság; B – sértetlenség; C – rendelkezésre állás; D – elsősorban bizalmasság.

Adatbiztonsági alapfogalmak

Mi veszélyezteti az adatainkat?

Fenyegetések:

-  emberi
-  technikai
-  fizikai
-  hálózati
-  szervezeti

Példák:

- adathalászat
- kártevő
- lopás
- tűz
- áramszünet
- emberi hiba
- rosszul konfigurált rendszer

Adatbiztonsági alapfogalmak

Fenyegetés és sérülékenység

FENYEGETÉS - Ami kárt okozhat.

SÉRÜLÉKENYSÉG - Olyan gyengeség, amely kihasználható.

PÉLDA:

Fenyegetés: BETÖRŐ

Sérülékenység: NYITVA HAGYOTT AJTÓ

Következmény: BEJUTÁS

Mi a sérülékenység egy hónapok óta nem frissített gépen?

Adatbiztonsági alapfogalmak

Kockázat

Kockázat

- Fenyegetés + sérülékenység
- lehetséges káros esemény
- következmény



Példa

- Elavult szerver + támadó
- jogosulatlan hozzáférés
- adatlopás

Adatbiztonsági alapfogalmak

A négy fogalom egy történetben

- „A NYITOTT AJTÓ”
- Fenyegetés
- Sérülékenység
- Kockázat
- Incidens
- Betörő
- Nyitva hagyott ajtó
- Illetéktelen bejutás lehetősége
- A betörő ténylegesen bejut

Mi lenne a biztonsági intézkedés?

Adatbiztonsági alapfogalmak

Mi az adatbiztonsági incidens?

Olyan esemény, amely ténylegesen vagy potenciálisan veszélyezteti az információ bizalmasságát, sértetlenségét vagy rendelkezésre állását.

Példák:

- adatlopás
- jogosulatlan belépés
- adatszivárgás
- kártevőfertőzés
- adatvesztés
- rendszerleállás

Adatbiztonsági alapfogalmak

Incidenskártya: A rossz címzett

Egy munkatárs 250 ügyfél adatait tartalmazó Excel-fájlt küld ki. A címzésnél rossz címzettet választ.

KÉRDÉSEK:

1. Mi történt?
2. Melyik CIA-elem sérül?
3. Mi lehetett a sérülékenység?
4. Hogyan lehetett volna megelőzni?

Adatbiztonsági alapfogalmak

Azonosítás, hitelesítés, jogosultság

- | | |
|--------------------|--|
| • 1. AZONOSÍTÁS | Példa: |
| • „Ki vagy?” | • „Én vagyok Péter.” azonosítás |
| • 2. HITELESÍTÉS | • „Itt a jelszavam.” hitelesítés |
| • „Bizonyítsd be!” | |
| • 3. JOGOSULTSÁG | • „Megnézhetem az adatokat.” jogosultság |
| • „Mit tehetsz?” | |

Adatbiztonsági alapfogalmak

Mivel hitelesíthetjük a felhasználót?

AMIT TUD

- jelszó
- PIN

AMINK VAN

- token
- telefon
- intelligens kártya

AMIK VAGYUNK

- ujjlenyomat
- arcfelismerés

A jelszó + jelszó többtényezős hitelesítés?

Adatbiztonsági alapfogalmak

„Mindenki adminisztrátor”

Egy 50 fős vállalatban:

MINDEN MUNKATÁRS RENDSZERGAZDAI JOGOSULTSÁGOT KAP.

Mi lehet a probléma?

- nagyobb támadási felület
- nagyobb emberi hibakár
- jogosulatlan módosítás
- kompromittált fiók esetén nagyobb kár

LEGKISEBB JOGOSULTSÁG ELVE

Adatbiztonsági alapfogalmak

Adatvédelem ≠ adatbiztonság

ADATVÉDELEM

- mit és milyen feltételekkel kezelünk?
- jogszerűség
- célhoz kötöttség
- érintetti jogok

ADATBIZTONSÁG

- hogyan védjük az adatot?
- bizalmasság
- sértetlenség
- rendelkezésre állás
- technikai és szervezeti védelem

Adatbiztonsági alapfogalmak

A védelem három rétege

FIZIKAI

 zár  kamera  tűzvédelem

SZERVEZETI (adminisztratív)

 szabályzat  oktatás  incidenskezelés

TECHNIKAI

 titkosítás  tűzfal  mentés  többtényezős hitelesítés

A BIZTONSÁG NEM EGYETLEN TECHNOLÓGIA.

Adatbiztonsági alapfogalmak

A biztonsági mentés szerepe

MI TÖRTÉNIK ZSAROLÓVÍRUS ESETÉN?

- Adatok
-  Titkosítás
-  Nem hozzáférhető

MEGFELELŐ MENTÉS ESETÉN:

- Adatok
-  Biztonsági mentés
-  Visszaállítás

Melyik CIA-elemet támogatja elsősorban?

Adatbiztonsági alapfogalmak

Feladat

Egy vállalat adatbiztonsági problémája

ESET – 50 FŐS VÁLLALAT

- közös mappában ügyfélszerződések
- minden munkatárs hozzáfér
- nincs részletes jogosultságkezelés
- munkatárs otthonról letölti
- saját laptopot használ
- a laptop nincs titkosítva
- laptopot ellopják
- nincs dokumentált mentési rend

Adatbiztonsági alapfogalmak

Auditori feladat

AZONOSÍTSÁK:

1. Mi az információs vagyon?
2. Mi a fenyegetés?
3. Milyen sérülékenységek vannak?
4. Mely CIA-elemek kerülnek veszélybe?
5. Milyen intézkedéseket javasolnának?
6. Ki legyen felelős?

Adatbiztonsági alapfogalmak

Az eset lehetséges megoldása

PROBLÉMA → KOCKÁZAT → LEHETSÉGES INTÉZKEDÉS

Mindenki hozzáfér → jogosulatlan hozzáférés → jogosultságok felülvizsgálata

Saját laptop → adatvesztés/szivárgás → vállalati eszköz, szabályozás

Nincs titkosítás → adat hozzáférhetővé válhat → eszköztitkosítás

Nincs mentési rend → adatvesztés → dokumentált mentés

Nincs részletes jogosultság → jogosulatlan módosítás → legkisebb jogosultság

Adatbiztonsági alapfogalmak

Mit vigyünk haza?

ADATBIZTONSÁG

Mit védünk? adatot és információs vagyont

Mitől? fenyegetésektől és sérülékenységek kihasználásától

Mit akarunk megőrizni?

- **BIZALMASSÁG**
- **SÉRTETLENSÉG**
- **RENDELKEZÉSRE ÁLLÁS**

Hogyan? fizikai + szervezeti + technikai intézkedésekkel

Honnan tudjuk, hogy megfelelő-e? ellenőrzéssel, méréssel és audittal

Adatbiztonsági alapfogalmak